本地优先与隐私边界

本地优先的含义

本地优先不是 " 永远不联网 " ，而是 " 原始数据默认留在本机，联网是可选项且可控 " 。

在这个项目里，文档读取、分块、嵌入、索引、检索全部在本机完成。生成阶段可以选择云端或本地：云端质量更高，但需要把少量检索片段发送出去；本地模式断网可用，数据零出站。

出站内容的最小化

云端模式不应该上传整份文档。合理的做法是只发送与问题相关的 ｔｏｐ - ｋ 片段，加上用户的问题本身。

发送前要能让用户看到具体内容：哪些片段、来自哪个文件、共多少字符。用户可以选择单次不发送，或者把某些来源加入黑名单。

本地模式则应该完全不产生外部请求。验证方式不是 " 相信代码 " ，而是断网运行并检查日志或抓包。

密钥与配置

ＡＰＩ 密钥只从环境变量读取，不写入代码，不提交到仓库，也不出现在日志里。

配置文件提供示例模板，真实配置放在被忽略的本地文件里。这样换机器时知道需要哪些变量，又不会泄露密钥。

读取范围的显式化

个人知识库不应该扫描整个硬盘。用户显式配置允许读取的目录，系统只遍历这些目录。

扫描日志要记录读了哪些文件、跳过了哪些文件、失败原因是什么。这样用户能审计系统到底碰了什么。

隐私作为工程能力

隐私不是一句口号，而是一组可验证的机制：最小出站、发送前预览、单次关闭、来源黑名单、本地零出站、日志可审计。

这些机制也适合在面试中展开，因为它们同时涉及架构抽象、数据流和工程约束。